The Last Quarter Century of Computer Security Research: Lessons Learned and Provocations for AI and AI Ethics

Tadayoshi Kohno
(Georgetown University)

AAAI/ACM Conference on AI, Ethics, and Society
October 14, 2026
Malmö, Sweden

Computer Security, a Definition

A field studying **computation** in the presence of an **adversary**

Computer Security, a Definition

A field studying **computation** in the presence of an **adversary**

- An **adversary** is a **stakeholder** who **seeks to harm** or **wrong** another stakeholder
- Example stakeholders: Governments, vendors, other companies, criminals, coworkers, friends, families, intimate partners

Computer Security, a Definition

A field studying **computation** in the presence of an **adversary**

- An **adversary** is a **stakeholder** who **seeks to harm** or **wrong** another stakeholder
- Example stakeholders: Governments, vendors, other companies, criminals, coworkers, friends, families, intimate partners

Field focus:

- Understanding how those harms or wrongs might manifest
- Developing methods to mitigate those harms or wrongs

Computer Security, a Definition

A field studying **computation** in the presence of an **adversary**

- An **adversary** is a **stakeholder** who **seeks to harm** or **wrong** another stakeholder

Computer Security, a Definition

A field studying **computation** in the presence of an **adversary**

- An **adversary** is a **stakeholder** who **seeks to harm** or **wrong** another stakeholder

Computer Security, a Definition

A field studying **computation** in the presence of an **adversary**

- An **adversary** is a **stakeholder** who **seeks to harm** or **wrong** another stakeholder

Computer Security, a Definition (Rewriting)

A field studying **computation** in the presence of a **stakeholder** who **seeks to harm** or **wrong** another stakeholder

Computer Security, a Definition (Rewriting)

A field studying **computation** in the presence of a **stakeholder** who **seeks to harm** or **wrong** another stakeholder

Changing “seeks to” to “has the potential to”

A field studying **computation** in the presence of a **stakeholder** who **has the potential to harm** or **wrong** another stakeholder

Changing “seeks to” to “has the potential to”

A field studying **computation** in the presence of a **stakeholder** who **has the potential to harm** or **wrong** another stakeholder

This **definition encompasses** (at least my definition of) the field of **AI, Ethics, and Society**

Changing “seeks to” to “has the potential to”

A field studying **computation** in the presence of a **stakeholder** who **has the potential to harm** or **wrong** another stakeholder

- Example stakeholders: Governments, vendors, other companies, criminals, coworkers, friends, families, intimate partners

This **definition encompasses** (at least my definition of) the field of **AI, Ethics, and Society**

This Talk: Premise and Provocation

Premise

Significant thematic overlap between **computer security** research and **AI, Ethics, and Society** research

This Talk: Premise and Provocation

Premise

Significant thematic overlap between **computer security** research and **AI, Ethics, and Society** research

Provocation

Considerations in AI, Ethics, and Society research can be **enriched** through a **reflection of the computer security field's evolution and practices**

This Talk: Background and Hope for the Future

Background:

- The computer industry was a "**mess**" with respect to **computer security** in the **Dot-Com Era** (late 1990s to early 2000s)
- **Computer security** is much **better today** thanks to research efforts

This talk:

- There are **parallels** between **AI today** and **computer security in the Dot-Com Era**
- There is **hope** for the future of AI, Ethics, and Society, too

A Brief History of Computer Security Research through the Dot-Com Years

Examples of Computer Security Research Directions and Impact
and
Considerations for AI Research

A Case Study of Microsoft and Trustworthy Computing
and
Threat Modeling

Where I’m Coming From — and — Only One View

- My perspective: Largely **U.S.-centric** and **only one window** in the computer security community
- ~1992-1993: First “official” contact with the computer security community (phone call from Phil Zimmerman, author of PGP)
- ~1994-1998: UNIX systems administrator, authored a Windows SSH client (but didn’t publicly release due to US export restrictions at the time)
- **1998**: Attended my first USENIX Security Symposium, presented a work-in-progress talk about SSH
- **1999-2001**: Cryptography and security consultant during the Dot-Com Era
- 2001-Present: UC San Diego (PhD student) → University of Washington (faculty) → Georgetown University (faculty)

A Brief History of Computer Security Research through the Dot-Com Years

Examples of Computer Security Research Directions and Impact
and
Considerations for AI Research

A Case Study of Microsoft and Trustworthy Computing
and
Threat Modeling

Companies and Consumers in the Late 1990s and Early 2000s

Increased connectivity:

- ~1995: AOL started mailing floppy disks with free AOL access
- 1995: Microsoft added native dial-up networking capabilities to Windows 95 (Windows 3.1 lacked a native dial-up networking)

The result:

- More people online
- New apps and services
- Start of the Dot-Com Era

Companies and Consumers in the Late 1990s and Early 2000s

Increased connectivity:

- ~1995: AOL started mailing floppy disks with free AOL access
- 1995: Microsoft added native dial-up networking capabilities to Windows 95 (Windows 3.1 lacked a native dial-up networking)

The result:

- More people online
- New apps and services
- Start of the Dot-Com Era

The Dot-Com Era was a time of significant innovation **without** today's foundations for how to build secure systems

Perspectives on Security

Companies did not feel pressure to prioritize security:

- Some attackers seemed hypothetical and unlikely to manifest
- Companies producing software did not bear the costs of attacks
- Companies prioritized competition on new technologies and features, not security
- Consumers could not tell if a product had high or low security

Security researchers did not trust companies to prioritize security

Perspectives on Security

Companies did not feel pressure to prioritize security:

- Some attackers seemed hypothetical and unlikely to manifest
- Companies producing software did not bear the costs of attacks
- Companies prioritized competition on new technologies and features, not security
- Consumers could not tell if a product had high or low security



Wiley 2000

Security researchers did not trust companies to prioritize security

Perspectives on Security

Companies did not feel pressure to prioritize security:

- Some attackers seemed hypothetical and unlikely to manifest
- Companies producing software did not bear the costs of attacks
- Companies prioritized competition on new technologies and features, not security
- Consumers could not tell if a product had high or low security



Wiley 2000

Why Information Security is Hard
– An Economic Perspective

Ross Anderson

ACSAC 2001

Security researchers did not trust companies to prioritize security

Numerous Vulnerabilities and Tensions with Companies

Upon finding a vulnerability in a product, a researcher could:

- Disclose the vulnerability to the product manufacturer privately
- Disclose the vulnerability to the public

In the 1990s and early 2000s:

- Companies would not fix privately disclosed vulnerabilities without public pressure
- Companies would threaten researchers not to speak publicly about vulnerabilities

Security researchers did not trust companies to fix (security) problems

Numerous Vulnerabilities and Tensions with Companies

"Full disclosure": The best practice for security researchers in the late 1990s and early 2000s:

- Do *not* disclose the vulnerability first to companies
- *Do* disclose the vulnerability first the the public
- Let public pressure, including media, pressure companies into fixing the vulnerability

(Today, "best practice" is coordinated disclosure, which assumes that companies are trustworthy and gives them time to fix the vulnerability before the vulnerability becomes public)

Security researchers did not trust companies to fix (security) problems

Significant (security) incidents and harms started to manifest

The “Golden Age” of Self-Replicating Internet Worms

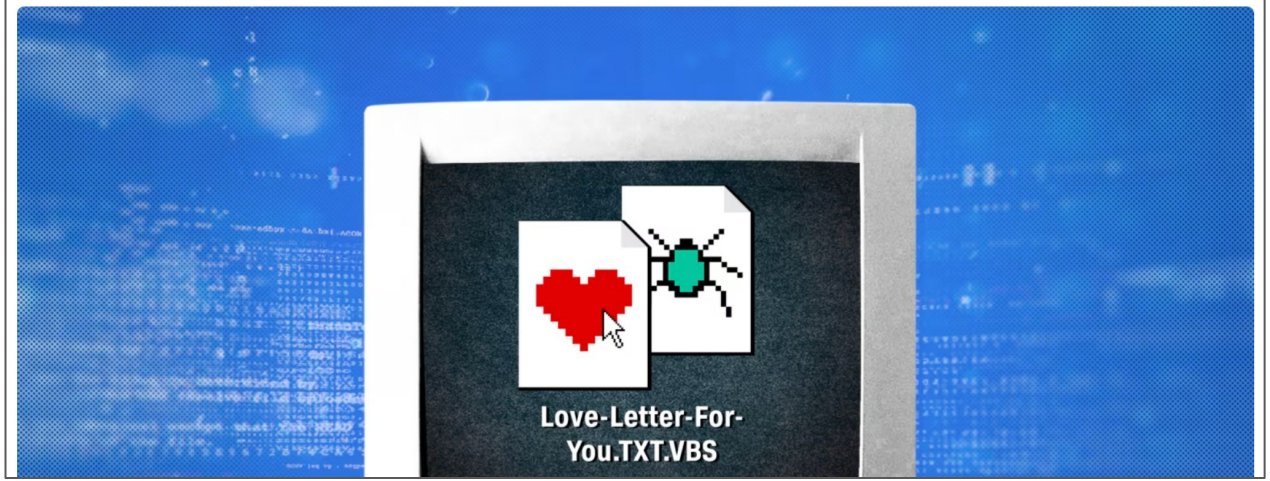
Significant (security) incidents and harms started to manifest

The “Golden Age” of Self-Replicating Internet Worms

‘I love you’: How a badly-coded computer virus caused billions in damage and exposed vulnerabilities which remain 20 years on

UPDATED MAY 3, 2020

By James Griffiths, CNN Business



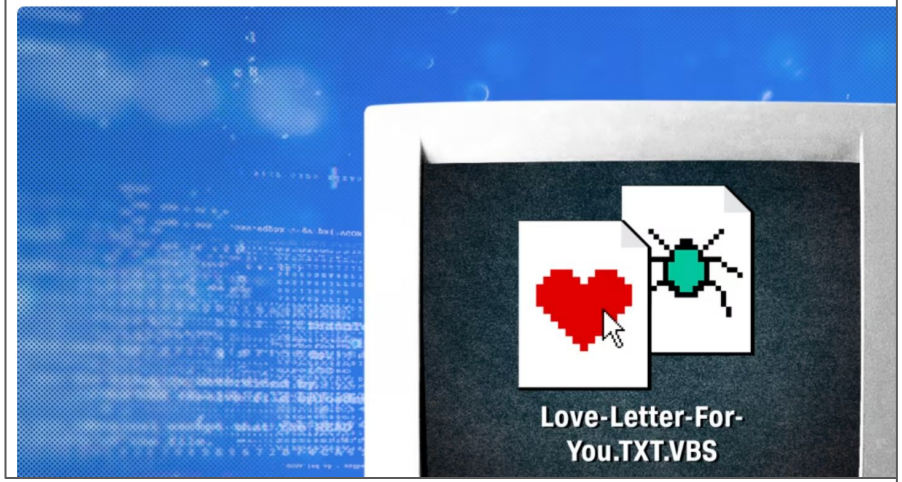
Significant (security) incidents and harms started to manifest

The “Golden Age” of Self-Replicating Internet Worms

‘I love you’: How a badly-coded computer virus caused billions in damage and exposed vulnerabilities which remain 20 years on

UPDATED MAY 3, 2020

By James Griffiths, CNN Business



'Code Red' Continues to Spread

By Peter Dizikes
August 1, 2001, 10:54 AM

Follow ABC News on Google

Share

N E W   Y O R K, Aug. 1 -- The Code Red computer worm has been rapidly tunneling its way around the globe today, but the FBI is hopeful that it will not cause extensive problems.

"Based on preliminary analysis, we expect a level of worm activity comparable to the July 19th Code Red infection, which resulted in infection of over 250,000 systems," says a statement released by the FBI's National Infrastructure Protection Center (NIPC) today. The

Significant (security) incidents and harms started to manifest

The “Golden Age” of Self-Replicating Internet Worms

‘I love you’: How a badly-coded computer virus caused billions in damage and exposed vulnerabilities which remain 20 years on

UPDATED MAY 3, 2020

By James Griffiths, CNN Business

A Worm Named Nimda

By CBSNews.com Staff

September 18, 2001 / 1:51 PM EDT / CBS

Add CBS News on Google

Nimda, the latest computer worm, has taken its show on the road.

The virus-like program has been shutting down Internet sites in Norway, Japan and other nations. Meanwhile, in the U.S., the Nimda worm is starting to abate.

The Nimda computer virus spread at dizzying speed through parts of Asia for a second day on Thursday. But experts said the worldwide outbreak may be close to peaking for the powerful server machines that drive the Web.

'Code Red' Continues to Spread

By Peter Dizikes
August 1, 2001, 10:54 AM

Follow ABC News on Google

Share

N E W   Y O R K, Aug. 1 -- The Code Red computer worm has been rapidly tunneling its way around the globe today, but the FBI is hopeful that it will not cause extensive problems.

"Based on preliminary analysis, we expect a level of worm activity comparable to the July 19th Code Red infection, which resulted in infection of over 250,000 systems," says a statement released by the FBI's National Infrastructure Protection Center (NIPC) today. The

Significant (security) incidents and harms started to manifest

The “Golden Age” of Self-Replicating Internet Worms

‘I love you’: How a badly-coded computer virus caused billions in damage and exposed vulnerabilities which remain 20 years on

UPDATED MAY 3, 2020

By  James Griffiths, CNN Business

A Worm Named Nimda

By CBSNews.com Staff

September 18, 2001 / 1:51 PM EDT / CBS

WIRED NEWSLETTERS

PAUL BOUTIN JUL 1, 2003 12:00 PM

Slammed!

An inside view of the worm that crashed the Internet in 15 minutes. “Gah!” Owen Maresh almost choked when the Priority 1 alert popped up on his panel of screens just after midnight on Saturday, January 25. Sitting inside Akamai’s Network Operations Control Center, the command room for 15,000 high-speed servers stationed around the globe, [...]

'Code Red' Continues to Spread

By Peter Dizikes
August 1, 2001, 10:54 AM

Follow ABC News on Google Share

N E W   Y O R K, Aug. 1 -- The Code Red computer worm has been rapidly tunneling its way around the globe today, but the FBI is hopeful that it will not cause extensive problems.

"Based on preliminary analysis, we expect a level of worm activity comparable to the July 19th Code Red infection, which resulted in infection of over 250,000 systems," says a statement released by the FBI's National Infrastructure Protection Center (NIPC) today. The

In the Dot-Com Era: Some Things Were Going Well…

There were stakeholders doing good things for security

- (**Some**) **software vendors** were trying to **improve** the **security** of their systems
- **Security consulting companies** offered assistance
- **Standards bodies** were thinking about security
- **U.S. government** was working toward a new symmetric encryption standard

Academic conferences existed, e.g.:

- **IEEE Symposium on Security and Privacy** founded in **1980**
- **USENIX Security** founded in **1988**
- **USENIX Security 1998** received **65 submissions** and published **18 papers**

In the Dot-Com Era: But…

On the not-positive side, there was also:

- Companies **lacked** the **knowledge** and **tools** to “get security right”
- **Rapid innovation** and **deployment** of new technologies
- Companies prioritized **innovation over security**
- There were **widespread problems** (vulnerabilities)
- There were **significant incidents** (self-propagating worms)
- **Distrust** in **companies** to do the “right thing” on their own
- (Also distrust in governments)

In the Dot-Com Era: But…

How different is this “early” state of computer security (1990s and early 2000s) from the state of AI now?

On the not-positive side, there was also:

- Companies **lacked** the **knowledge** and **tools** to “get security right”
- **Rapid innovation** and **deployment** of new technologies
- Companies prioritized **innovation over security**
- There were **widespread problems** (vulnerabilities)
- There were **significant incidents** (self-propagating worms)
- **Distrust** in **companies** to do the “right thing” on their own
- (Also distrust in governments)

In the Dot-Com Era: But…

How different is this “early” state of computer security (1990s and early 2000s) from the state of AI now?

On the not-positive side, there was also:

- Companies **lacked** the **knowledge** and **tools** to “get security right”
- **Rapid innovation** and **deployment** of new technologies
- Companies prioritized **innovation over security**
- There were **widespread problems** (vulnerabilities)
- There were **significant incidents** (self-propagating worms)
- **Distrust** in **companies** to do the “right thing” on their own
- (Also distrust in governments)

Amidst the “chaos”, security researchers were striving to advance security

Today, Computer Security is Much Better

Computer security is much better now:

- Companies (generally) (1) care and (2) have tools to help with security
- Researchers and companies (generally) work together

Of course

- Companies are still producing systems that have insecurities
- Not all companies take security vulnerabilities seriously
- New attack methods are manifesting
- Users do not always trust companies and governments

Today, Computer Security is Much Better

Computer security is much better now:

- Companies (generally) (1) care and (2) have tools to help with security
- Researchers and companies (generally) work together

Of course

- Companies are still producing systems that have insecurities
- Not all companies take security vulnerabilities seriously
- New attack methods are manifesting
- Users do not always trust companies and governments

There will always be more for researchers to do ...

Today, Computer Security is Much Better

Computer security is much better now:

- Companies (generally) (1) care and (2) have tools to help with security
- Researchers and companies (generally) work together

Of course

- Companies are still producing systems that have insecurities
- Not all companies take security vulnerabilities seriously
- New attack methods are manifesting
- Users do not always trust companies and governments

There will always be more for researchers to do ...

Still, the state of computer security became better once we advanced our understanding ⇒ the same will apply to AI, Ethics, and Society

A Brief History of Computer Security Research through the Dot-Com Years

Examples of Computer Security Research Directions and Impact
and
Considerations for AI Research

A Case Study of Microsoft and Trustworthy Computing
and
Threat Modeling

Eight Categories of Security Research for This Talk

- Uncovering Risks with Technology
- Deep Exploration of Risk Categories
- Measurement Studies and Tools
- Studies with People
- Risk Assessment Tools for Non-Experts
- Secure/Safe Building Blocks
- Detection and Deterrence
- New Solutions

On Connections to AI

Each time I make a connection, I encourage you to think about your “favorite” AI technology

On Connections to AI

Each time I make a connection, I encourage you to think about your “favorite” AI technology

My core discipline is computer security

- There are undoubtedly more connections to AI, Ethics, and Society
- I am eager to learn of other connections

1. Uncovering Risks with Technology

Security researchers discover security risks with systems

Knowledge of these risks can help:

- Companies secure their systems
- Users be more secure
- Entire industries change their practices

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Network Security

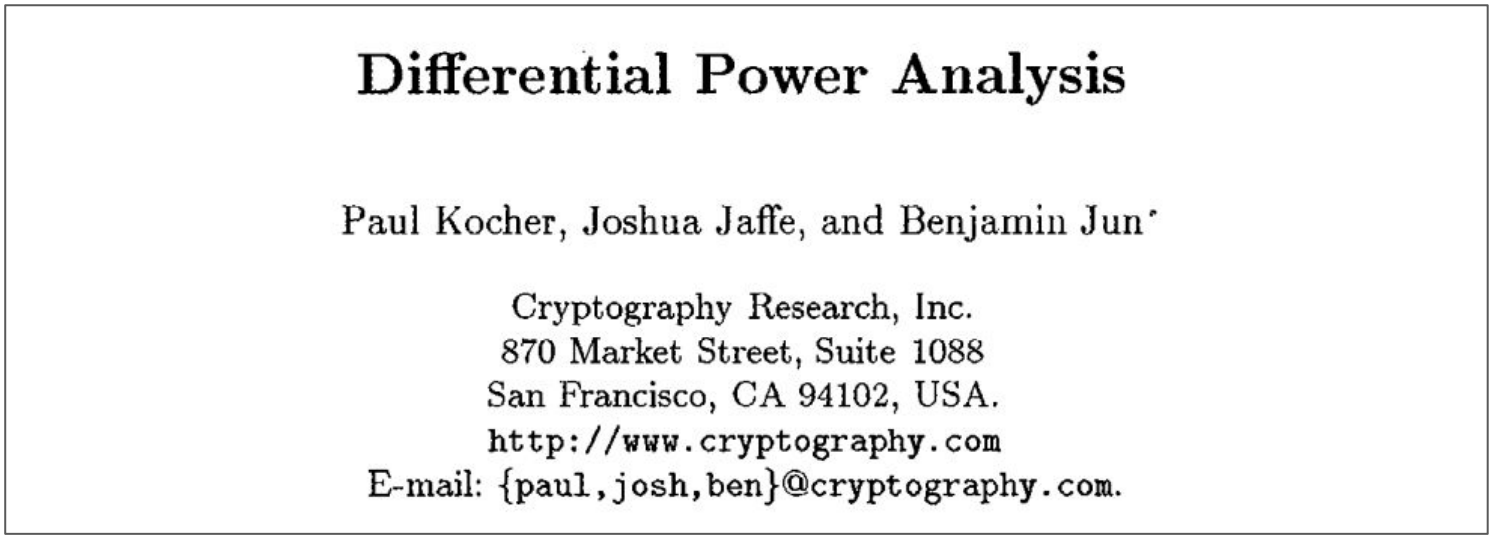
Problem Areas for the IP Security Protocols

Steven M. Bellovin
smb@research.att.com
AT&T Research

USENIX Security 1996

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Smartcard Security



Differential Power Analysis

Paul Kocher, Joshua Jaffe, and Benjamin Jun*

Cryptography Research, Inc.
870 Market Street, Suite 1088
San Francisco, CA 94102, USA.
http://www.cryptography.com
E-mail: {paul,josh,ben}@cryptography.com.

Crypto 1999

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

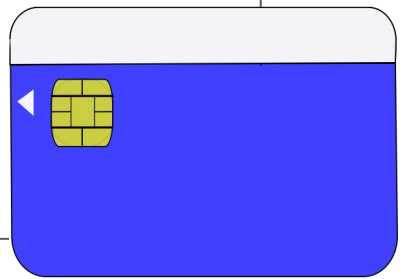
1. Uncovering Risks with Technology: Smartcard Security

Differential Power Analysis

Paul Kocher, Joshua Jaffe, and Benjamin Jun*

Cryptography Research, Inc.
870 Market Street, Suite 1088
San Francisco, CA 94102, USA.
http://www.cryptography.com
E-mail: {paul,josh,ben}@cryptography.com.

Crypto 1999



Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Web Security

Dos and Don'ts of Client Authentication on the Web

Kevin Fu, Emil Sit, Kendra Smith, Nick Feamster
{fubob, sit, kendras, feamster}@mit.edu
MIT Laboratory for Computer Science
http://cookies.lcs.mit.edu/

USENIX Security 2001

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Wireless Medical Devices

Pacemakers and Implantable Cardiac Defibrillators: Software Radio Attacks and Zero-Power Defenses

Daniel Halperin† — University of Washington

Thomas S. Heydt-Benjamin† — University of Massachusetts Amherst

Benjamin Ransford† — University of Massachusetts Amherst

Shane S. Clark — University of Massachusetts Amherst

Benessa Defend — University of Massachusetts Amherst

Will Morgan — University of Massachusetts Amherst

Kevin Fu, PhD* — University of Massachusetts Amherst

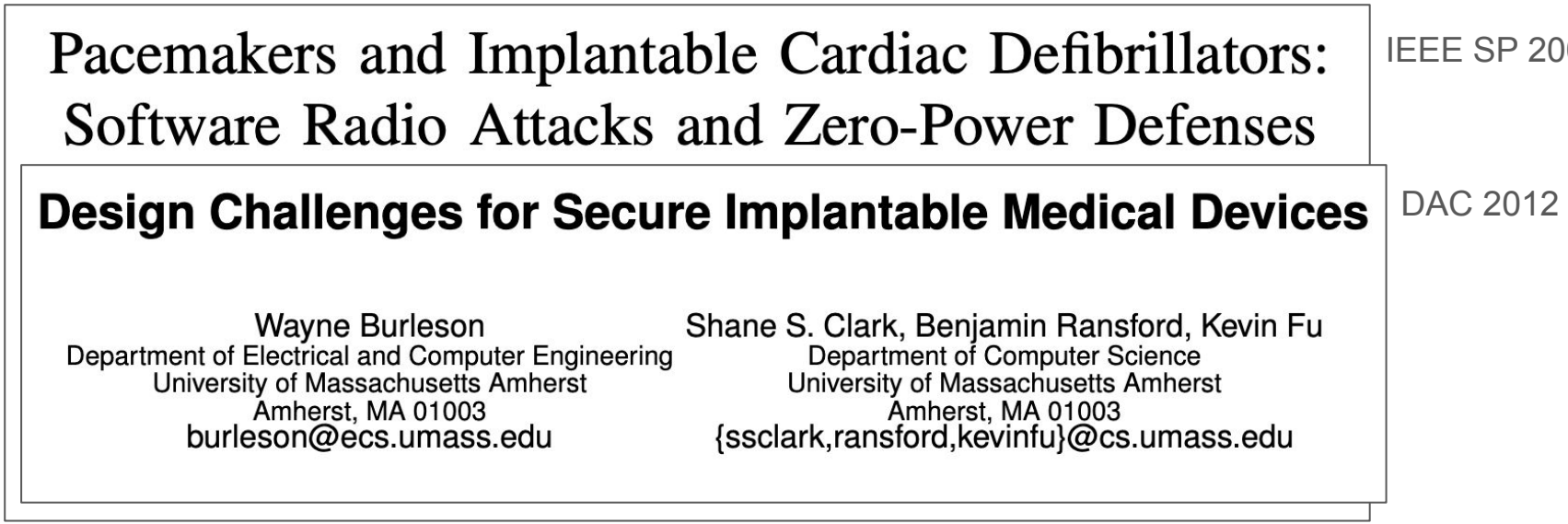
Tadayoshi Kohno, PhD* — University of Washington

William H. Maisel, MD, MPH* — BIDMC and Harvard Medical School

IEEE SP 2008

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Wireless Medical Devices



Pacemakers and Implantable Cardiac Defibrillators: Software Radio Attacks and Zero-Power Defenses

IEEE SP 2008

Design Challenges for Secure Implantable Medical Devices

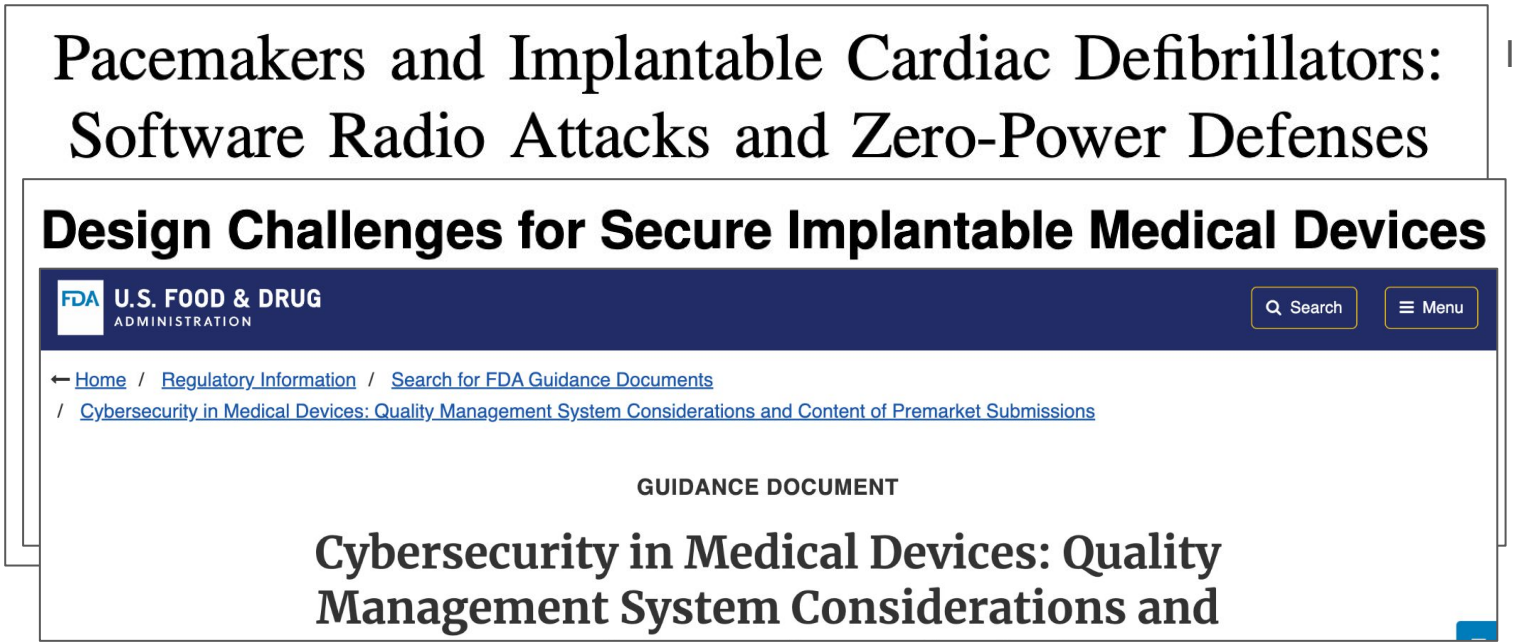
DAC 2012

Wayne Burleson
Department of Electrical and Computer Engineering
University of Massachusetts Amherst
Amherst, MA 01003
burleson@ecs.umass.edu

Shane S. Clark, Benjamin Ransford, Kevin Fu
Department of Computer Science
University of Massachusetts Amherst
Amherst, MA 01003
{ssclark,ransford,kevinfu}@cs.umass.edu

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Wireless Medical Devices



IEEE SP 2008

DAC 2012

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Modern Automobiles

Experimental Security Analysis of a Modern Automobile

Karl Koscher, Alexei Czeskis, Franziska Roesner, Shwetak Patel, and Tadayoshi Kohno
Department of Computer Science and Engineering
University of Washington
Seattle, Washington 98195–2350
Email: {supersat,aczeskis,franzi,shwetak,yoshi}@cs.washington.edu

Stephen Checkoway, Damon McCoy, Brian Kantor, Danny Anderson, Hovav Shacham, and Stefan Savage
Department of Computer Science and Engineering
University of California San Diego
La Jolla, California 92093–0404
Email: {s,dlmccoy,brian,d8anders,hovav,savage}@cs.ucsd.edu

IEEE SP 2010

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Modern Automobiles

Experimental Security Analysis of a Modern Automobile

IEEE SP 2010

Comprehensive Experimental Analyses of Automotive Attack Surfaces

Stephen Checkoway, Damon McCoy, Brian Kantor,
Danny Anderson, Hovav Shacham, and Stefan Savage
University of California, San Diego

Karl Koscher, Alexei Czeskis, Franziska Roesner, and Tadayoshi Kohno
University of Washington

USENIX Security 2011

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Modern Automobiles

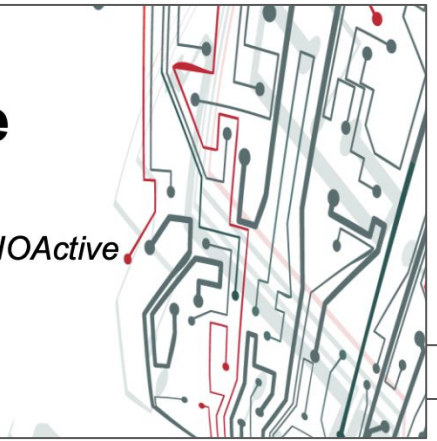
Experimental Security Analysis of a Modern Automobile

Comprehensive Experimental Analyses of Automotive Attack Surfaces

Remote Exploitation of an Unaltered Passenger Vehicle

Chris Valasek, Director of Vehicle Security Research for IOActive
chris.valasek@ioactive.com

Charlie Miller, Security Researcher for Twitter
cmiller@openrce.org



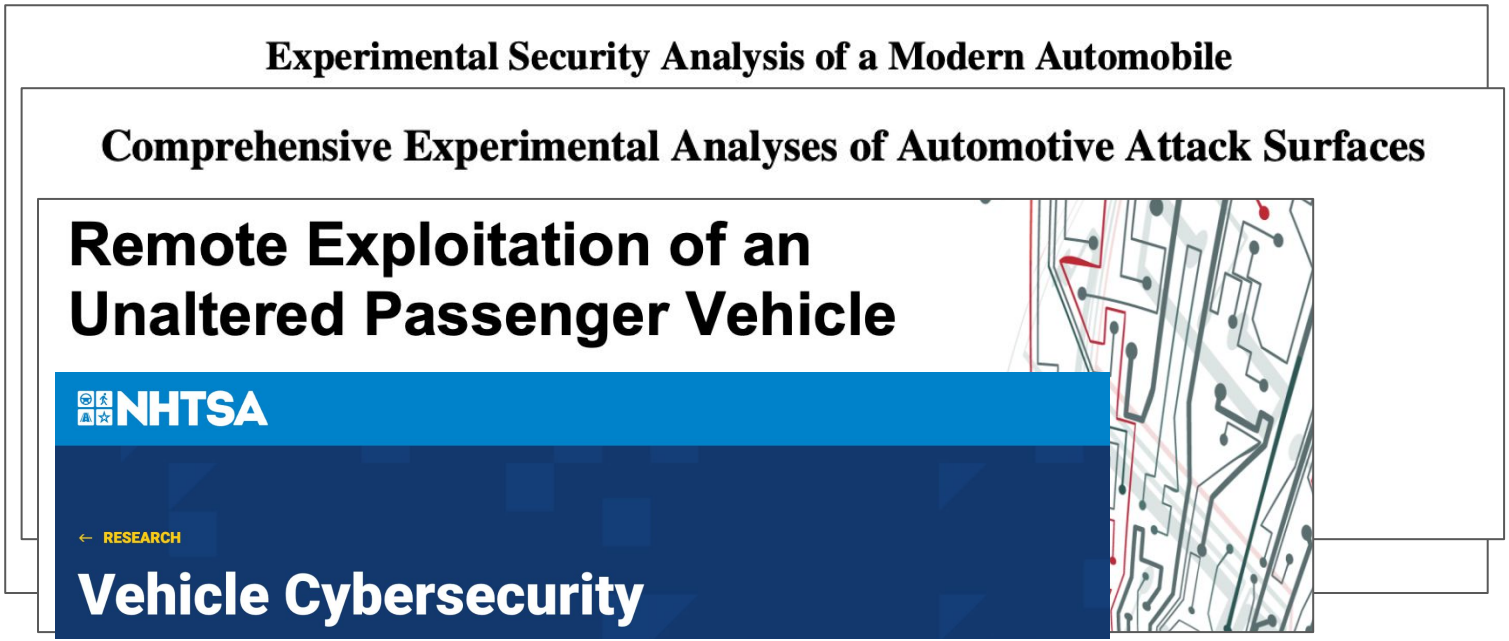
IEEE SP 2010

USENIX Security 2011

Defcon 2015

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Modern Automobiles



IEEE SP 2010

USENIX Security 2011

Defcon 2015

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology and AI

Studies that uncover (potential) risks with AI technologies are having / will have impact:

- Biases in resume screeners
- Biases in face recognition systems
- Biases in image generators
- *Novel risks with your "favorite" AI technology*

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

1. Uncovering Risks with Technology: Lingering Tensions



Car key immobiliser hack revelations blocked by UK court

29 July 2013

Megamos Crypto transponders are built into car keys to disable the vehicles' engine immobilisers

A High Court judge has blocked three security researchers from publishing details of how to crack a car immobilisation system.

USENIX Security 2013

Research discovering and assessing risks can change entire fields of computing (research, industry, government)

2. Deep Exploration of Risk Categories

Once a category of risks is determined, there is significant value in:

- Extensively exploring how that risk might manifest
- Exploring how that risk might manifest in the presence of mitigations

Research extensively studying how particular risk manifest can provide a foundation for building better systems

2. Deep Exploration of Risk Categories: Buffer Overflows



Smashing The Stack For Fun And Profit

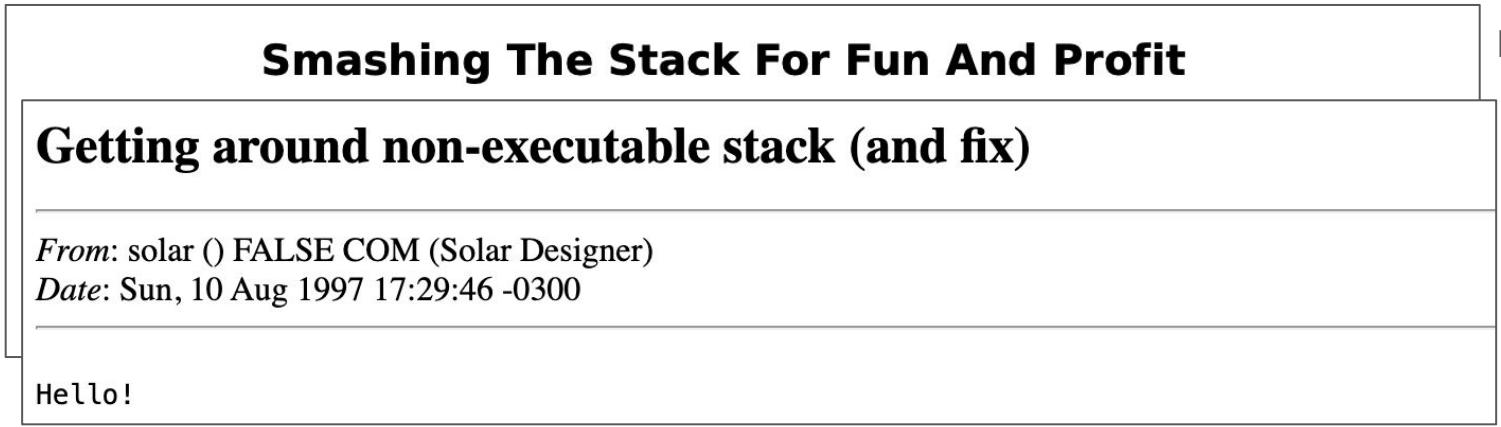
Aleph One

aleph1@underground.org

Phrack 1996

Research extensively studying how particular risk manifest can provide a foundation for building better systems

2. Deep Exploration of Risk Categories: Buffer Overflows

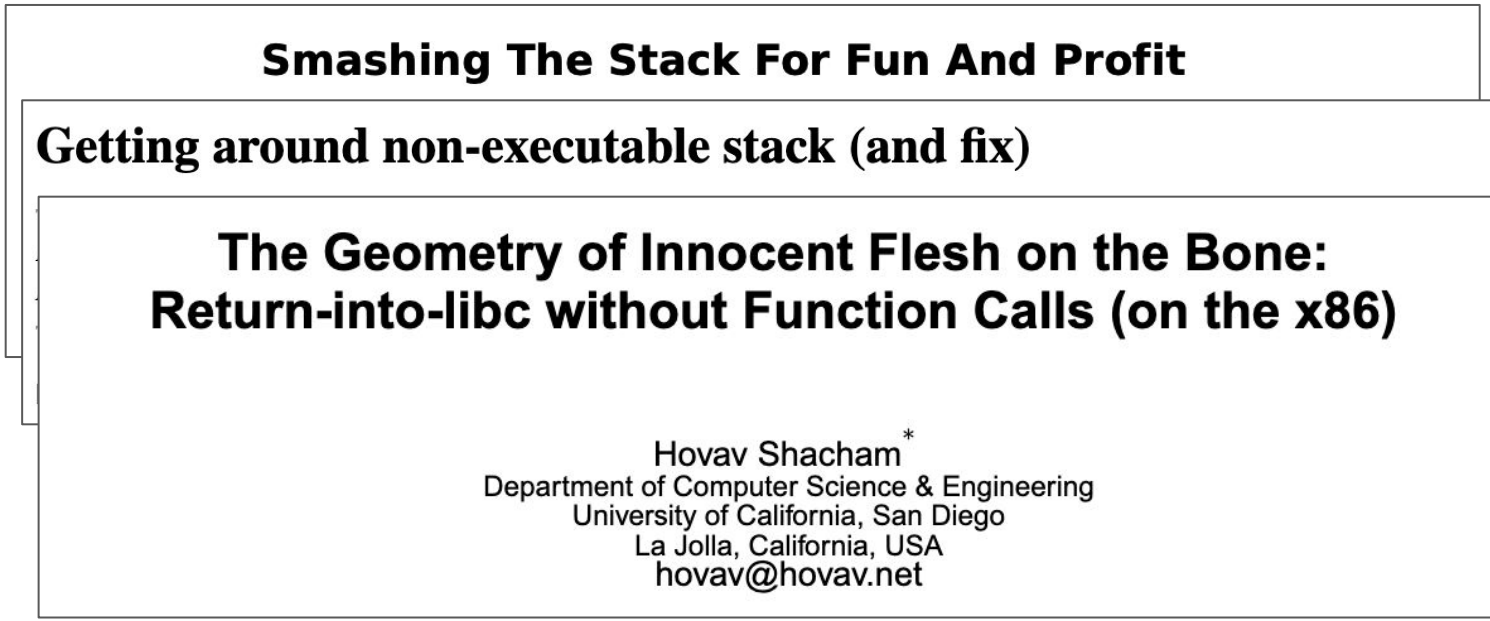


Phrack 1996

Bugtraq 1997

Research extensively studying how particular risk manifest can provide a foundation for building better systems

2. Deep Exploration of Risk Categories: Buffer Overflows



Phrack 1996

Bugtraq 1997

ACM CCS 2006

Research extensively studying how particular risk manifest can provide a foundation for building better systems

2. Deep Exploration of Risk Categories and AI

Studies that dive deeply into risks with AI technologies are/will have impact:

- Extensive explorations of different ways in which biases manifest in language models
- Extensive explorations of how biases manifest in text-to-image generation
- *Deeply study how a category of risks might manifest in your "favorite" AI technology*

Research extensively studying how particular risk manifest can provide a foundation for building better systems

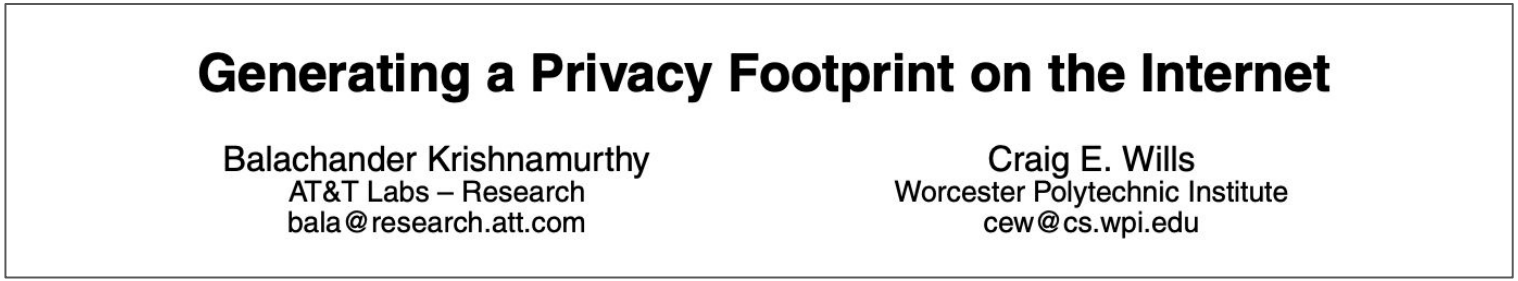
3. Measurement Studies and Tools

Measurement studies are studies in which security researchers

- Interact with existing services to assess people's exposure to harm
- Study how people use and interact with deployed systems

Research on measuring risks can inform understanding and risk mitigations

3. Measurement Studies and Tools: Third-Party Web Tracking



Generating a Privacy Footprint on the Internet

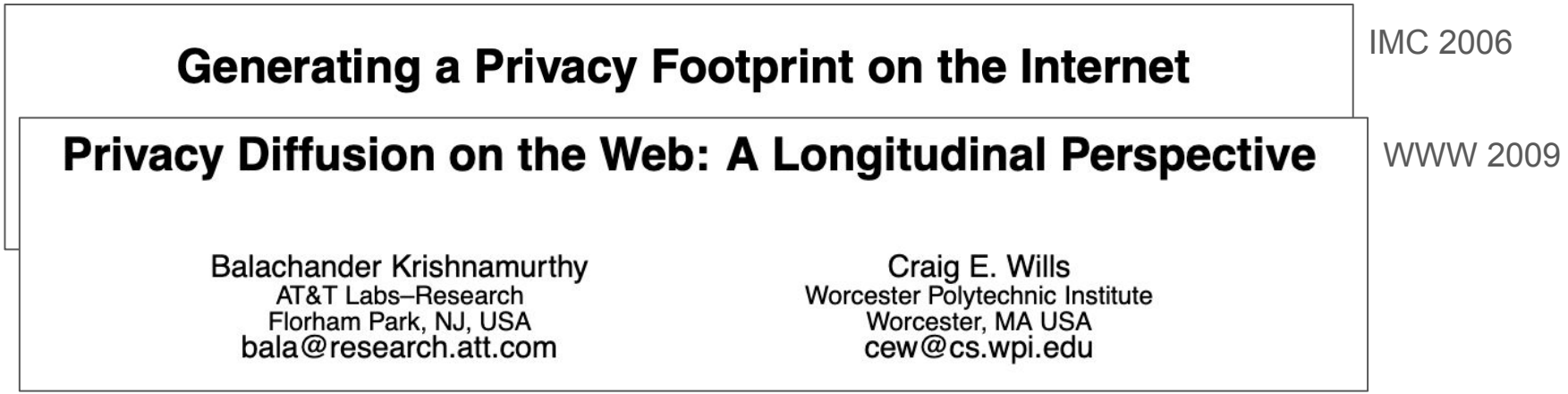
Balachander Krishnamurthy
AT&T Labs – Research
bala@research.att.com

Craig E. Wills
Worcester Polytechnic Institute
cew@cs.wpi.edu

IMC 2006

Research on measuring risks can inform understanding and risk mitigations

3. Measurement Studies and Tools: Third-Party Web Tracking



IMC 2006

WWW 2009

Research on measuring risks can inform understanding and risk mitigations

3. Measurement Studies and Tools: Third-Party Web Tracking

Generating a Privacy Footprint on the Internet — IMC 2006

Privacy Diffusion on the Web: A Longitudinal Perspective — WWW 2009

Detecting and Defending Against Third-Party Tracking on the Web — NSDI 2012

Franziska Roesner, Tadayoshi Kohno, and David Wetherall
University of Washington

Research on measuring risks can inform understanding and risk mitigations

3. Measurement Studies and Tools: Third-Party Web Tracking

Generating a Privacy Footprint on the Internet — IMC 2006

Privacy Diffusion on the Web: A Longitudinal Perspective — WWW 2009

Detecting and Defending Against Third-Party Tracking on the Web — NSDI 2012

Third-Party Web Tracking: Policy and Technology — IEEE SP 2012

Jonathan R. Mayer and John C. Mitchell
Stanford University Stanford, CA
{jmayer,mitchell}@cs.stanford.edu

Research on measuring risks can inform understanding and risk mitigations

3. Measurement Studies and Tools: Third-Party Web Tracking

Generating a Privacy Footprint on the Internet — IMC 2006

Privacy Diffusion on the Web: A Longitudinal Perspective — WWW 2009

Detecting and Defending Against Third-Party Tracking on the Web — NSDI 2012

Third-Party Web Tracking: Policy and Technology — IEEE SP 2012



Jonathan R. Mayer and John C. Mitchell
Stanford University Stanford, CA
{jmayer,mitchell}@cs.stanford.edu

ePrivacy Directive

Research on measuring risks can inform understanding and risk mitigations

3. Measurement Studies and Tools: Website Malware

Automated Web Patrol with Strider HoneyMonkeys:
Finding Web Sites That Exploit Browser Vulnerabilities

Yi-Min Wang
Doug Beck
Xuxian Jiang
Roussi Roussev

MSR 2005

Research on measuring risks can inform understanding and risk mitigations

3. Measurement Studies and Tools and AI

Examples of continual web crawls related to AI:

- Measure ubiquity of generative AI content on websites
- Measure ubiquity of AI chat interfaces on websites

Examples of continual app analyses related to AI:

- Measure text-to-image generation biases
- Measure properties of interactions with chat systems

A continual measurement of your "favorite" AI technology as deployed

Research on measuring risks can inform understanding and risk mitigations

4. Studies with People

Security researchers study how technologies are used in practice, focusing on:

- Direct stakeholders
- Indirect stakeholders

And use that knowledge to inform their understanding of

- How risks manifest in practice
- The design space for risk mitigations

Research with people informs understanding of how technologies are used and how risks manifest in practice

4. Studies with People: Studies within Security

Why Johnny Can't Encrypt:
A Usability Evaluation of PGP 5.0

Alma Whitten
School of Computer Science
Carnegie Mellon University
Pittsburgh, PA 15213
alma@cs.cmu.edu

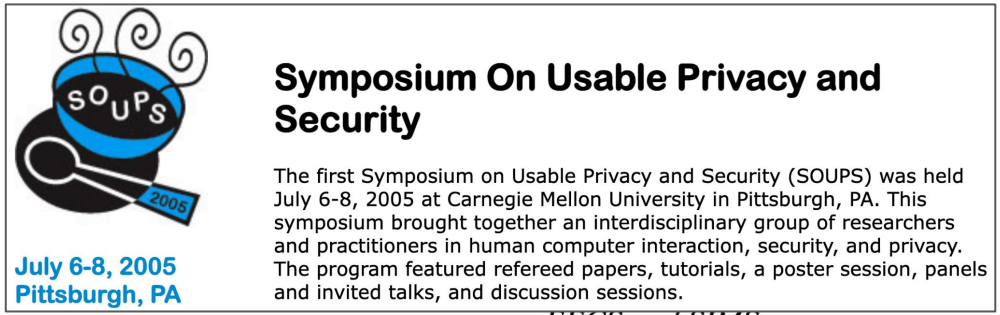
J. D. Tygar[1]
EECS and SIMS
University of California
Berkeley, CA 94720
tygar@cs.berkeley.edu

USENIX Security
1999

Research with people informs understanding of how technologies are used and how risks manifest in practice

4. Studies with People: Studies within Security

Why Johnny Can't Encrypt:
A Usability Evaluation of PGP 5.0

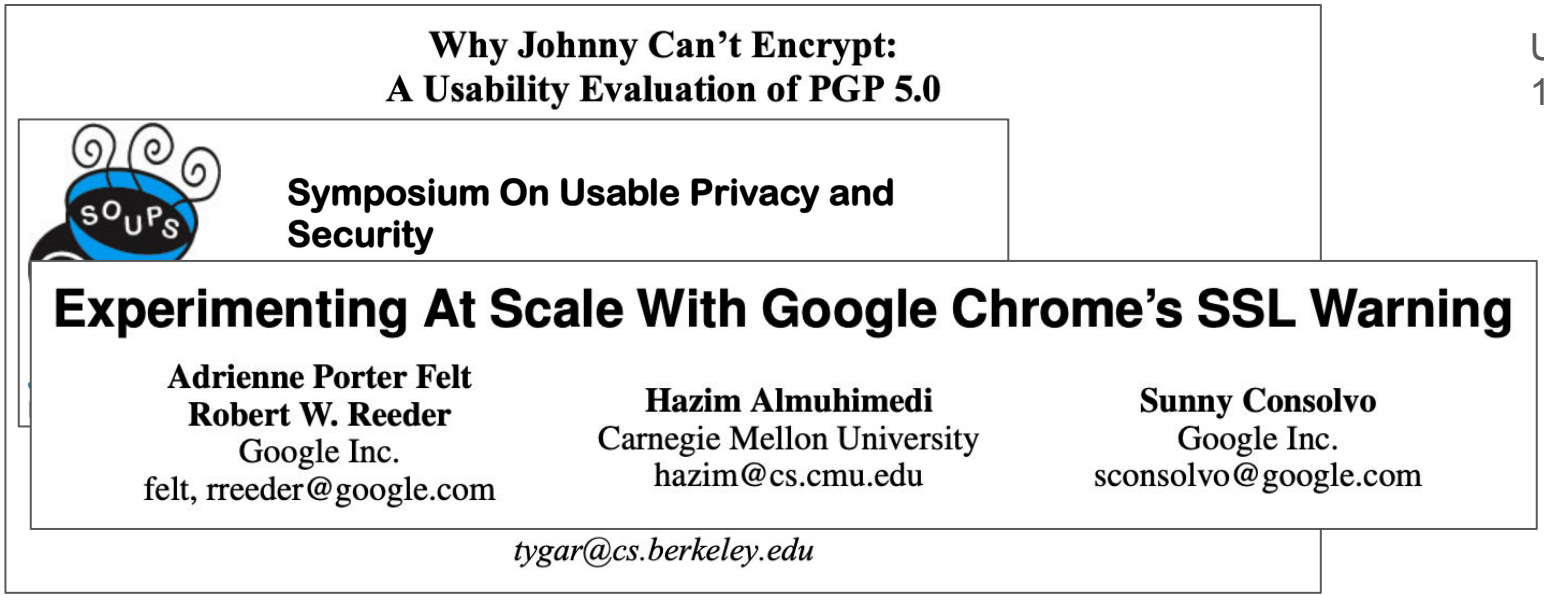


EECS and SIMS
University of California
Berkeley, CA 94720
tygar@cs.berkeley.edu

USENIX Security 1999

Research with people informs understanding of how technologies are used and how risks manifest in practice

4. Studies with People: Studies within Security



USENIX Security 1999

CHI 2014

Research with people informs understanding of how technologies are used and how risks manifest in practice

4. Studies with People: Studies within Security

Why Johnny Can't Encrypt:
A Usability Evaluation of PGP 5.0

USENIX Security 1999



Symposium On Usable Privacy and Security

Experimenting At Scale With Google Chrome's SSL Warning

CHI 2014

SoK: A Framework for Unifying At-Risk User Research

IEEE SP 2022

Noel Warford*, Tara Matthews†, Kaitlyn Yang*, Omer Akgul*, Sunny Consolvo†,
Patrick Gage Kelley†, Nathan Malkin*, Michelle L. Mazurek*, Manya Sleeper†, and Kurt Thomas†
*University of Maryland, †Google

Research with people informs understanding of how technologies are used and how risks manifest in practice

4. Studies with People and AI

AI research focused on understanding people — including direct and indirect stakeholders — will have impact

- Studies of how people interact with chat systems
- Studies of how people detect generative AI content
- Studies of how the use of AI systems impact people's lives
- *Studies of how people interact with your "favorite" AI system*

Research with people informs understanding of how technologies are used and how risks manifest in practice

5. Risk Assessment Tools for Non-Experts

There is significant value in developing tools that non-experts can use to evaluate the security of their systems

Research on tools for identifying risks can help non-expert systems builders

5. Risk Assessment Tools for Non-Experts: Software Analyses

A First Step Towards Automated Detection of Buffer Overrun Vulnerabilities*

David Wagner Jeffrey S. Foster Eric A. Brewer Alexander Aiken
University of California, Berkeley

NDSS 2000

Research on tools for identifying risks can help non-expert systems builders

5. Risk Assessment Tools for Non-Experts: Software Analyses

A First Step Towards Automated Detection of Buffer Overrun Vulnerabilities*

NDSS 2000

ITS4: A Static Vulnerability Scanner for C and C++ Code

John Viega, J.T. Bloch, Yoshi Kohno, Gary McGraw
Reliable Software Technologies
Dulles, Virginia
{jviega, jtbloch, kohno, gem}@rstcorp.com
http://www.rstcorp.com

ACSAC 2000

Research on tools for identifying risks can help non-expert systems builders

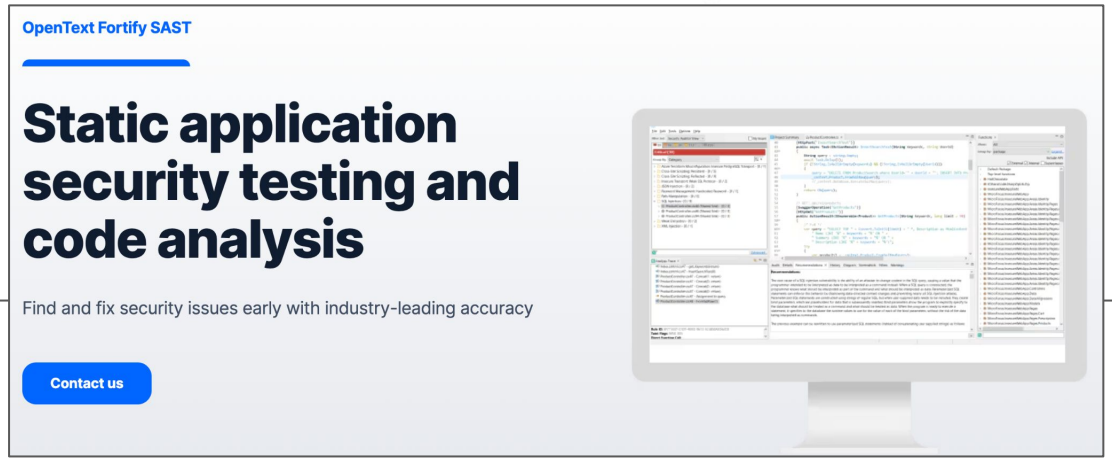
5. Risk Assessment Tools for Non-Experts: Software Analyses

A First Step Towards Automated Detection of Buffer Overrun Vulnerabilities*

NDSS 2000

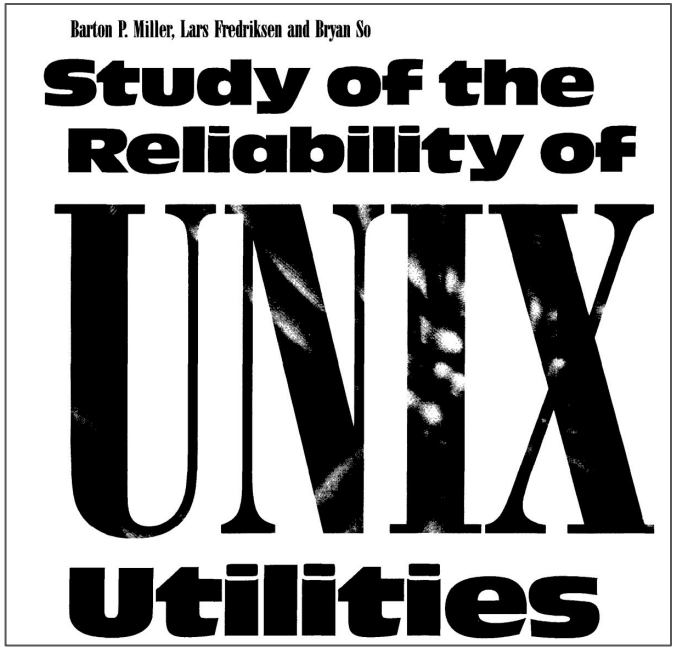
ITS4: A Static Vulnerability Scanner for C and C++ Code

ACSAC 2000



Research on tools for identifying risks can help non-expert systems builders

5. Risk Assessment Tools for Non-Experts: Software Analyses



CACM 1990

Research on tools for identifying risks can help non-expert systems builders

5. Risk Assessment Tools for Non-Experts and AI

There will likely be significant value in automated tools, for developers of systems that use AI, to detect:

- Biases in outputs
- Indications of not considering specific communities (e.g., accessibility, certain languages or backgrounds)
- Red-teaming of AI systems for target properties (e.g., information disclosure)
- *Tools to help systems builders detect risks with your "favorite" category of AI systems*

Research on tools for identifying risks can help non-expert systems builders

6. Secure/Safe Building Blocks

One thrust of computer security-related research focuses on the development of secure building-blocks

Research on secure/safe underlying components can increase the security/safety of deployed systems

6. Secure/Safe Building Blocks

Secure Coprocessors in Electronic Commerce Applications

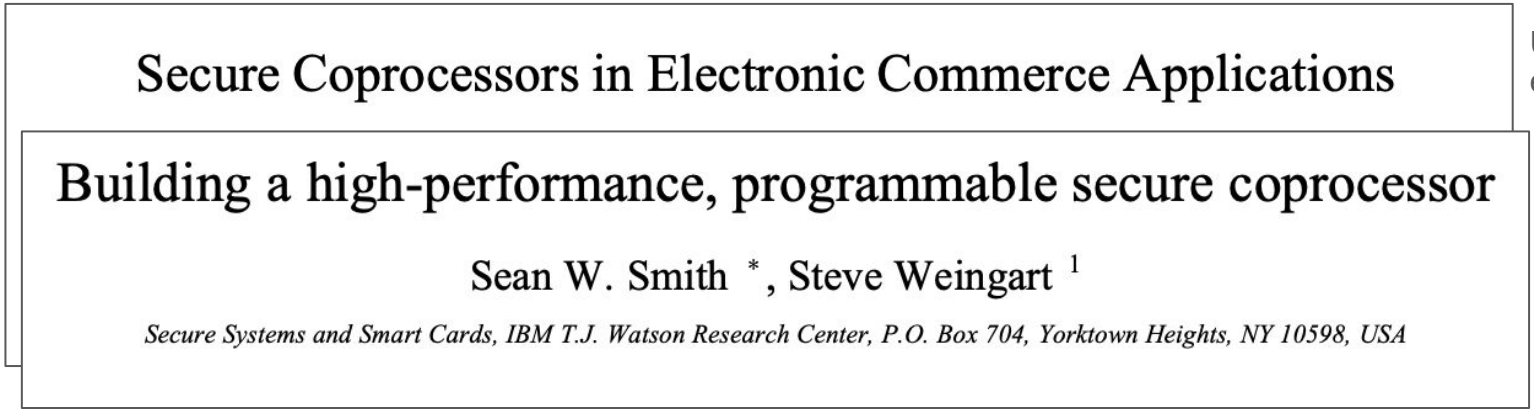
Bennet Yee
Microsoft Corporation
Redmond, WA 98052
bsy@microsoft.com

J. D. Tygar
Carnegie Mellon University
Pittsburgh, PA 15213
tygar@cs.cmu.edu

USENIX
e-Commerce 1995

Research on secure/safe underlying components can increase the security/safety of deployed systems

6. Secure/Safe Building Blocks



USENIX
e-Commerce 1995

Computer Networks
1999

Research on secure/safe underlying components can increase the security/safety of deployed systems

6. Secure/Safe Building Blocks

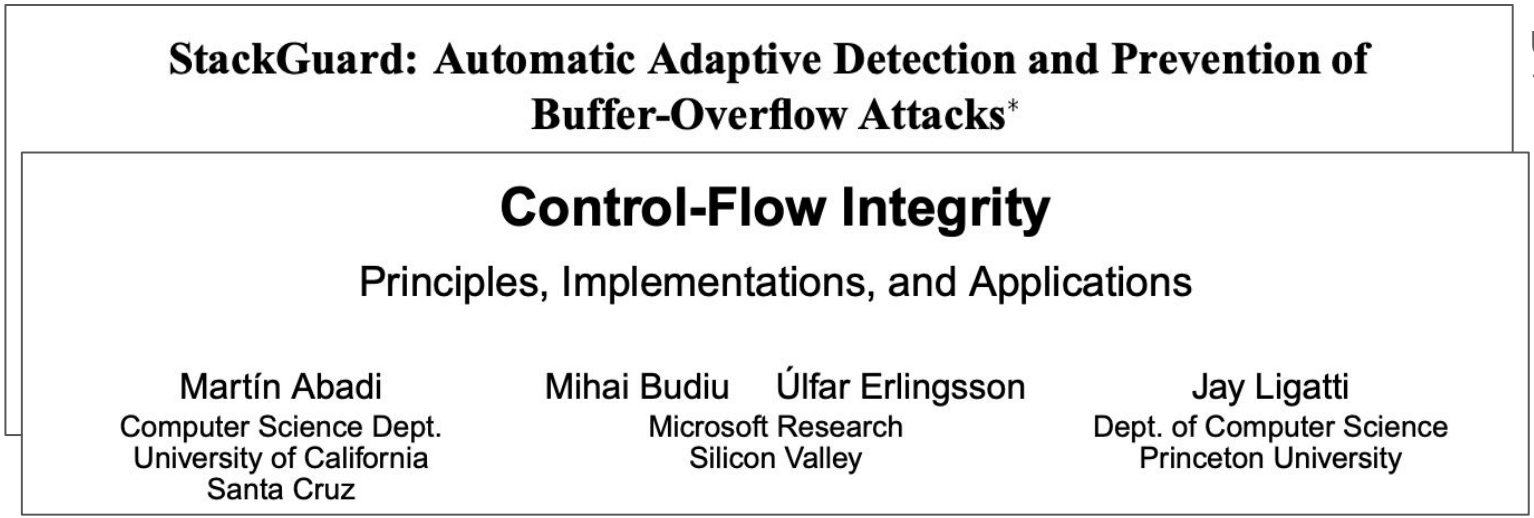
StackGuard: Automatic Adaptive Detection and Prevention of Buffer-Overflow Attacks*

Crispin Cowan, Calton Pu, Dave Maier, Heather Hinton†, Jonathan Walpole,
Peat Bakke, Steve Beattie, Aaron Grier, Perry Wagle and Qian Zhang
Department of Computer Science and Engineering
Oregon Graduate Institute of Science & Technology
immunix-request@cse.ogi.edu, http://cse.ogi.edu/DISC/projects/immunix

USENIX Security 1998

Research on secure/safe underlying components can increase the security/safety of deployed systems

6. Secure/Safe Building Blocks



StackGuard: Automatic Adaptive Detection and Prevention of Buffer-Overflow Attacks*

USENIX Security 1998

Control-Flow Integrity

Principles, Implementations, and Applications

Martín Abadi
Computer Science Dept.
University of California
Santa Cruz

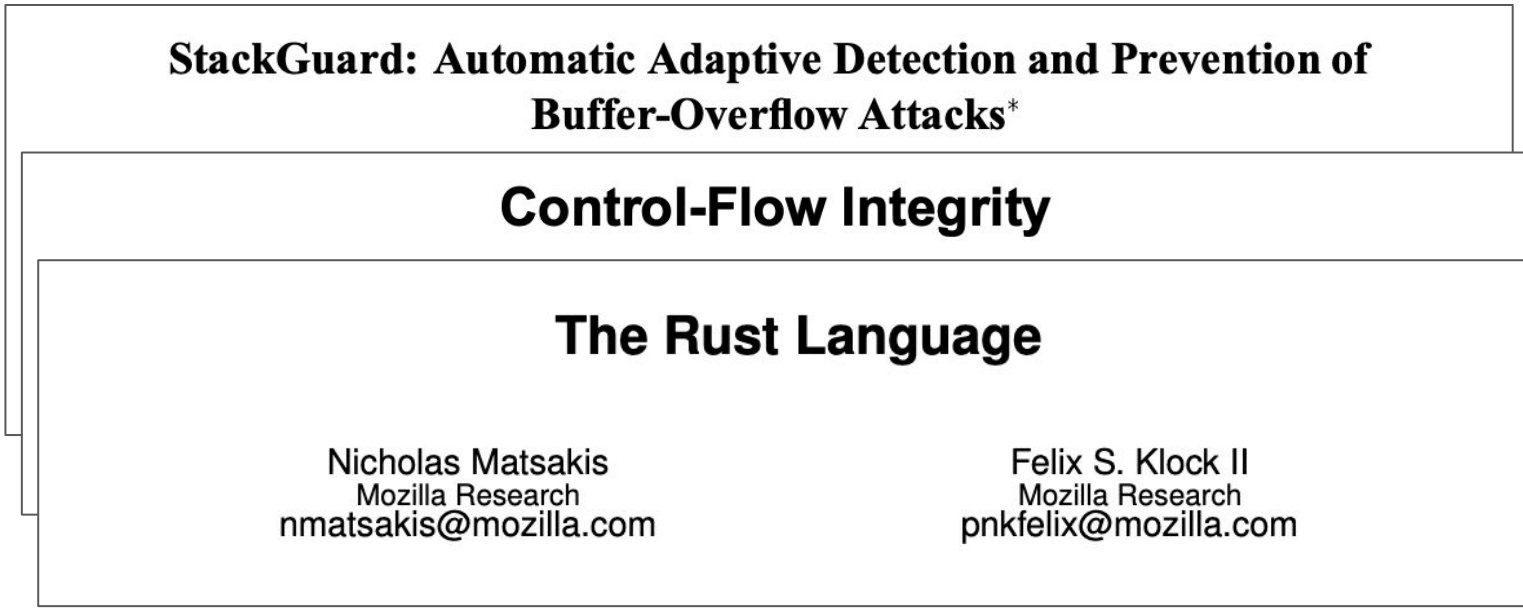
Mihai Budiu Úlfar Erlingsson
Microsoft Research
Silicon Valley

Jay Ligatti
Dept. of Computer Science
Princeton University

ACM CCS 2005

Research on secure/safe underlying components can increase the security/safety of deployed systems

6. Secure/Safe Building Blocks



USENIX Security 1998

ACM CCS 2005

HILT 2014

Research on secure/safe underlying components can increase the security/safety of deployed systems

6. Secure/Safe Building Blocks and AI

Research on building safe-by-default components for AI systems can have multiplicative impacts:

- “Safe” training data
- “Safe” models
- “Safe” benchmarks
- “Safe” frameworks for knowing when to involve users in agentic actions
- “Safe” methods for separating external data from user’s instructions
- “Safe” methods for containing/sandboxing the actions of AI systems
- *“Safety” for some other component upon which your “favorite” AI system builds*

Research on secure/safe underlying components can increase the security/safety of deployed systems

7. Detection and Deterrence

There are three pillars to computer security research:

- Prevention
- Detection
- Deterrence

Security researchers explore all three

Research on detection and deterrence can help mitigate risks when the first-line of protection fails

7. Detection and Deterrence: Real-time Detection and Forensics

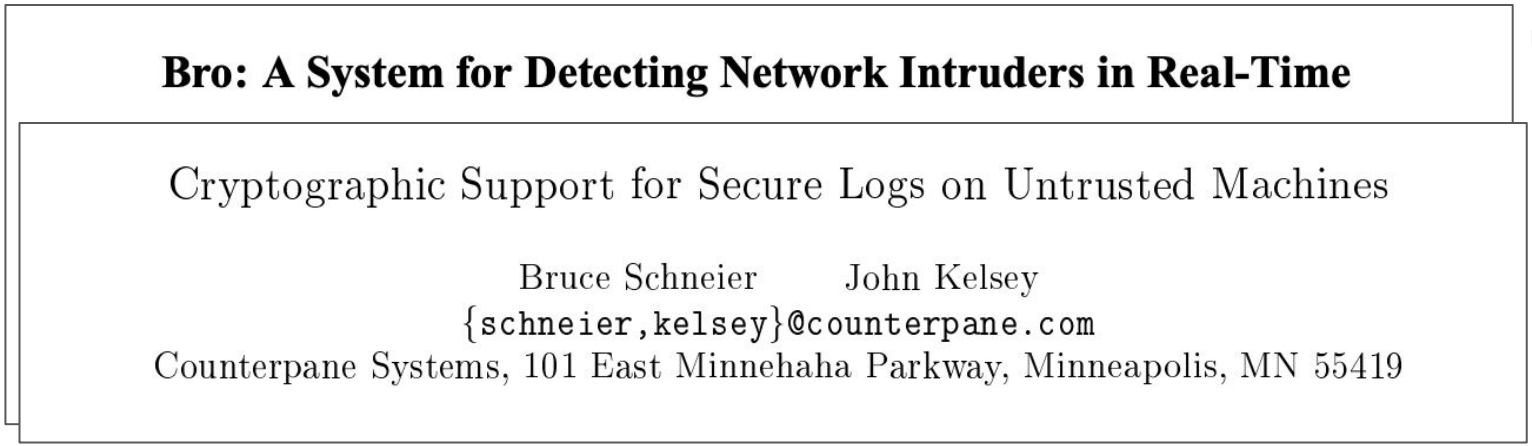
Bro: A System for Detecting Network Intruders in Real-Time

Vern Paxson
Network Research Group
*Lawrence Berkeley National Laboratory**
Berkeley, CA 94720
vern@ee.lbl.gov

USENIX Security 1998

Research on detection and deterrence can help mitigate risks when the first-line of protection fails

7. Detection and Deterrence: Real-time Detection and Forensics



USENIX Security 1998

USENIX Security 1998

Research on detection and deterrence can help mitigate risks when the first-line of protection fails

7. Detection and Deterrence and AI

For AI systems, there is also significant value in developing methods to:

- Detect when risks are about to manifest / are manifesting
- Offer forensic capabilities for after harms/wrongs manifest
- *Specific detection or deterrence mechanisms for your "favorite" AI system*

Research on detection and deterrence can help mitigate risks when the first-line of protection fails

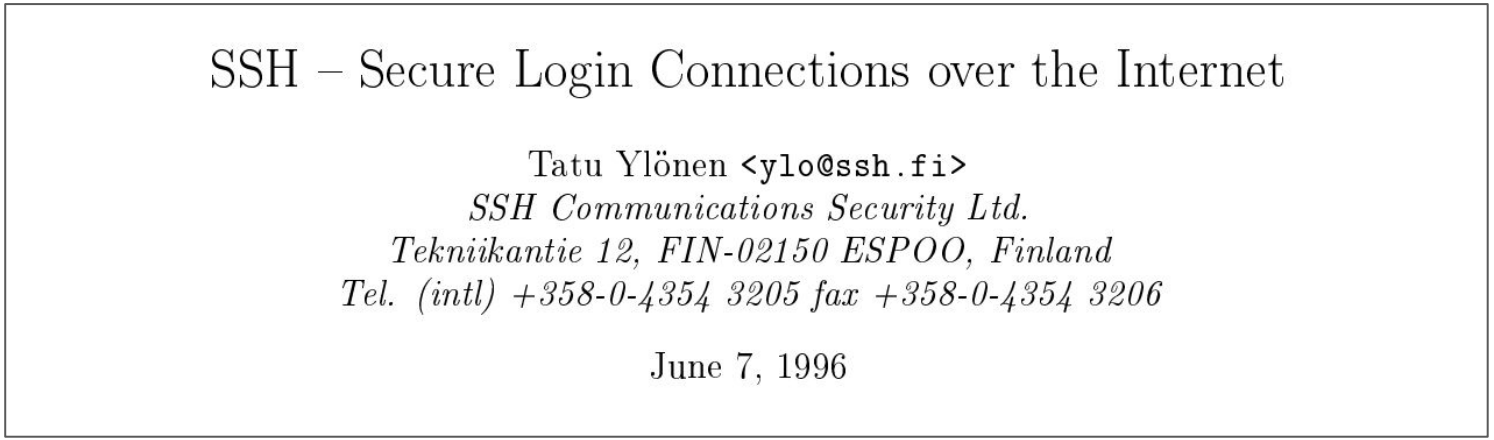
8. New Solutions

Security researchers also develop solutions to user-facing problems:

- How to communicate privately?
- How to verify the identity of a communicant?
- How to authenticate?
- How to set up a secure network?
- ...

Research on new solutions can increase security/safety

8. New Solutions: Securing Remote Connections



SSH – Secure Login Connections over the Internet

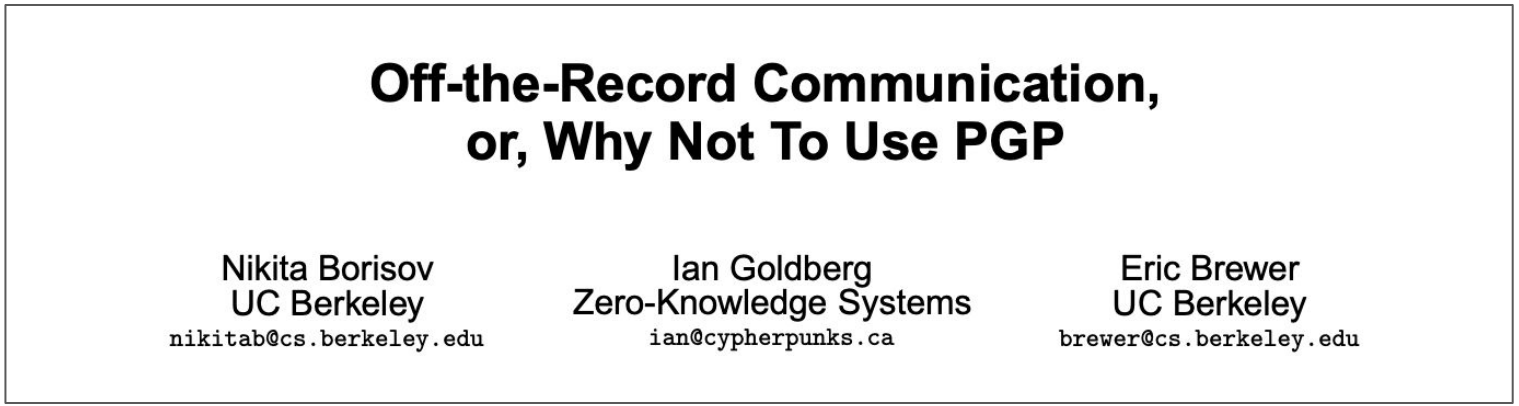
Tatu Ylönen <ylo@ssh.fi>
SSH Communications Security Ltd.
Tekniikantie 12, FIN-02150 ESPOO, Finland
Tel. (intl) +358-0-4354 3205 fax +358-0-4354 3206

June 7, 1996

USENIX Security 1996

Research on new solutions can increase security/safety

8. New Solutions: Off-the-Record Messaging



Off-the-Record Communication, or, Why Not To Use PGP

Nikita Borisov
UC Berkeley
nikitab@cs.berkeley.edu

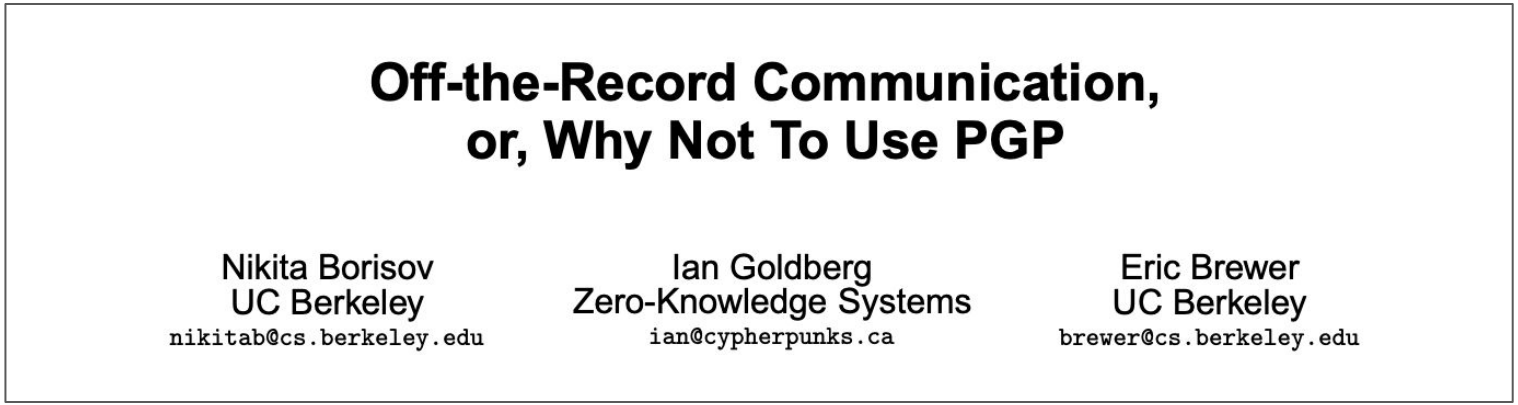
Ian Goldberg
Zero-Knowledge Systems
ian@cypherpunks.ca

Eric Brewer
UC Berkeley
brewer@cs.berkeley.edu

WPES 2004

Research on new solutions can increase security/safety

8. New Solutions: Off-the-Record Messaging



Off-the-Record Communication, or, Why Not To Use PGP

Nikita Borisov
UC Berkeley
nikitab@cs.berkeley.edu

Ian Goldberg
Zero-Knowledge Systems
ian@cypherpunks.ca

Eric Brewer
UC Berkeley
brewer@cs.berkeley.edu

WPES 2004

Signal

WhatsApp

Research on new solutions can increase security/safety

8. New Solutions: Anonymous Communications

Hiding Routing Information

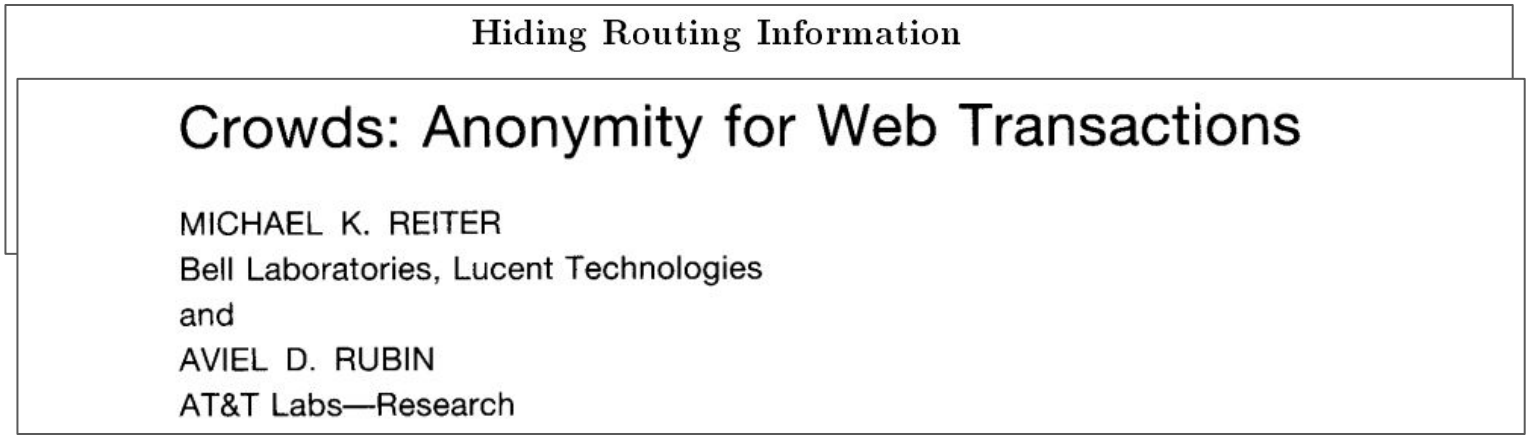
David M. Goldschlag, Michael G. Reed, and Paul F. Syverson

Naval Research Laboratory, Center For High Assurance Computer Systems,
Washington, D.C. 20375-5337, USA, phone: +1 202.404.2389, fax: +1 202.404.7942,
e-mail: {*last name*}@itd.nrl.navy.mil.

IH 1996

Research on new solutions can increase security/safety

8. New Solutions: Anonymous Communications

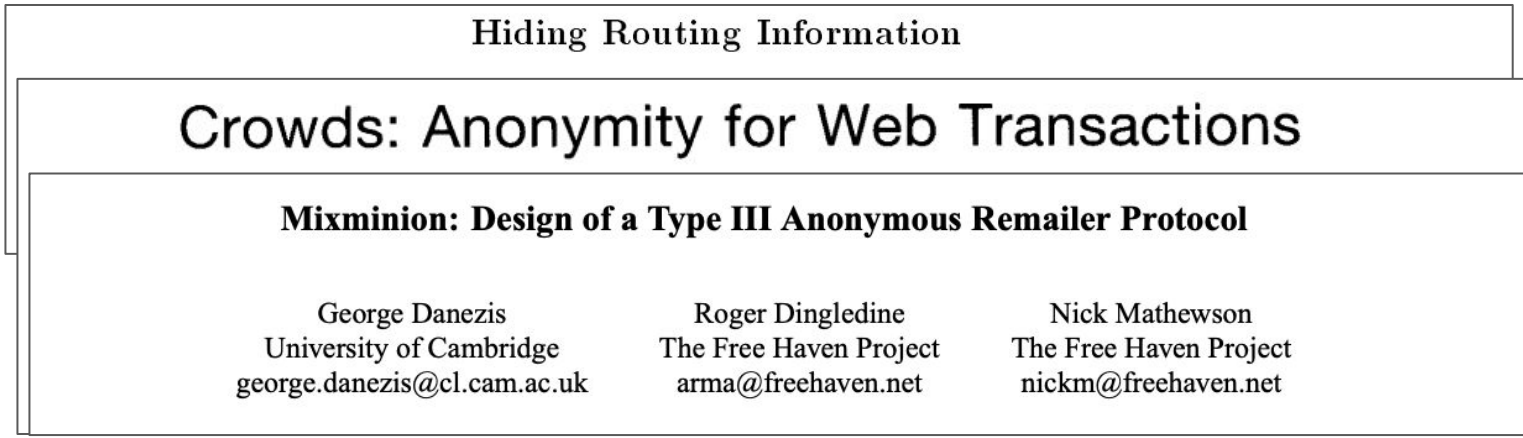


IH 1996

TISSEC 1998

Research on new solutions can increase security/safety

8. New Solutions: Anonymous Communications



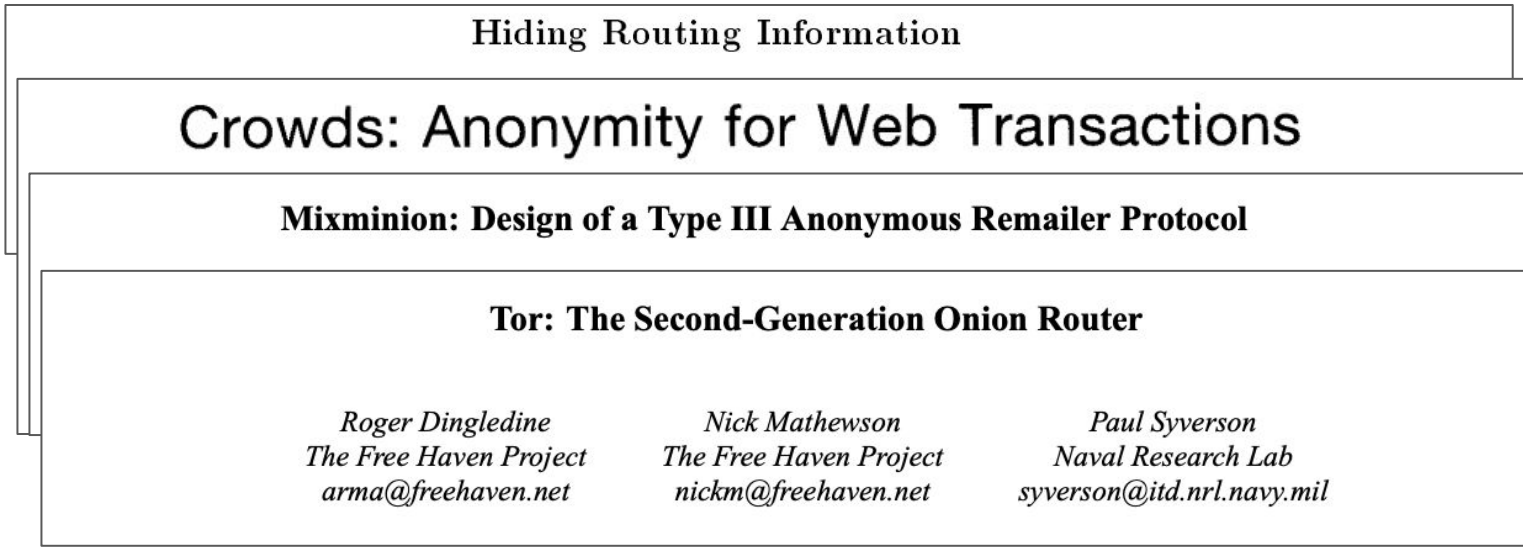
IH 1996

TISSEC 1998

IEEE S&P 2003

Research on new solutions can increase security/safety

8. New Solutions: Anonymous Communications



IH 1996

TISSEC 1998

IEEE S&P 2003

USENIX Security 2004

Research on new solutions can increase security/safety

8. New Solutions: Anonymous Communications

Hiding Routing Information

IH 1996

Crowds: Anonymity for Web Transactions

TISSEC 1998

Mixminion: Design of a Type III Anonymous Remailer Protocol

IEEE S&P 2003

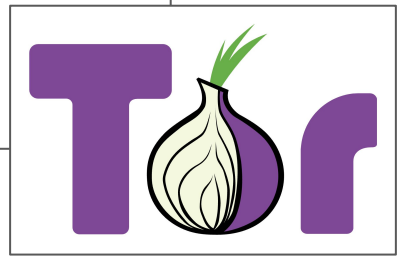
Tor: The Second-Generation Onion Router

USENIX Security 2004

Roger Dingledine
The Free Haven Project
arma@freehaven.net

Nick Mathewson
The Free Haven Project
nickm@freehaven.net

Paul Syverson
Naval Research Lab
syverson@itd.nrl.navy.mil



Research on new solutions can increase security/safety

8. New Solutions: Improving Authentication

Origin-Bound Certificates: A Fresh Approach to Strong Client Authentication for the Web

Michael Dietz
Rice University
mdietz@rice.edu

Alexei Czeskis
University of Washington
alexei@czeskis.com

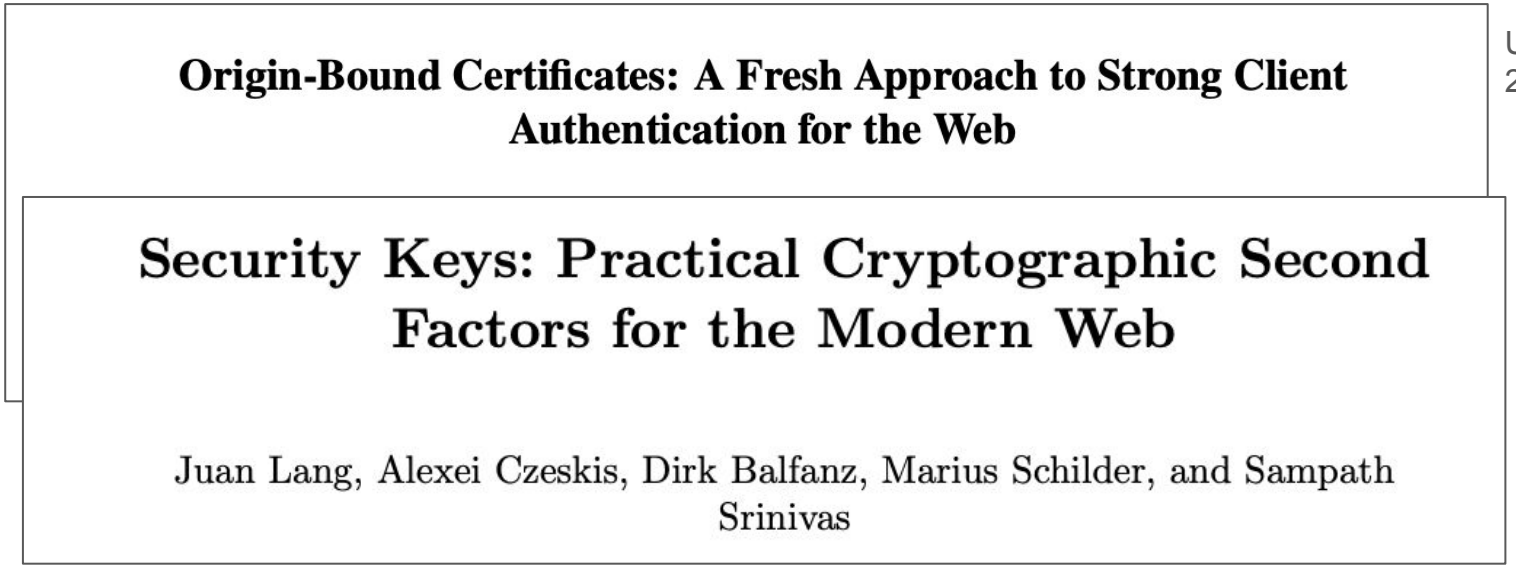
Dirk Balfanz*
Google Inc.
balfanz@google.com

Dan S. Wallach
Rice University
dwallach@rice.edu

USENIX Security 2012

Research on new solutions can increase security/safety

8. New Solutions: Improving Authentication



USENIX Security 2012

FC 2016

Research on new solutions can increase security/safety

8. New Solutions: Improving Authentication

Origin-Bound Certificates: A Fresh Approach to Strong Client Authentication for the Web

USENIX Security 2012

Security Keys: Practical Cryptographic Second Factors for the Modern Web

FC 2016



Google

Passkeys: One step closer to a passwordless future

Research on new solutions can increase security/safety

8. New Solutions and AI

This community — with its understanding of AI, Ethics, and Society — is positioned to design technologies are supportive of users, indirect stakeholders, and society

- Tools to help people recognize or avoid AI-generated content
- Tools to help people maintain autonomy when talking with chat systems
- *Tools to help people navigate your "favorite" AI problem*

Research on new solutions can increase security/safety

Eight Categories of Security Research for This Talk

- Uncovering Risks with Technology
- Deep Exploration of Risk Categories
- Measurement Studies and Tools
- Studies with People
- Risk Assessment Tools for Non-Experts
- Secure/Safe Building Blocks
- Detection and Deterrence
- New Solutions

Other Key Security Concepts

Defense-in-Depth: Systems should be designed to be secure even if one defensive mechanisms fails

Minimizing the Trusted Computing Base: The part of the system that needs to be trusted in order to mitigate harms should be as small as possible

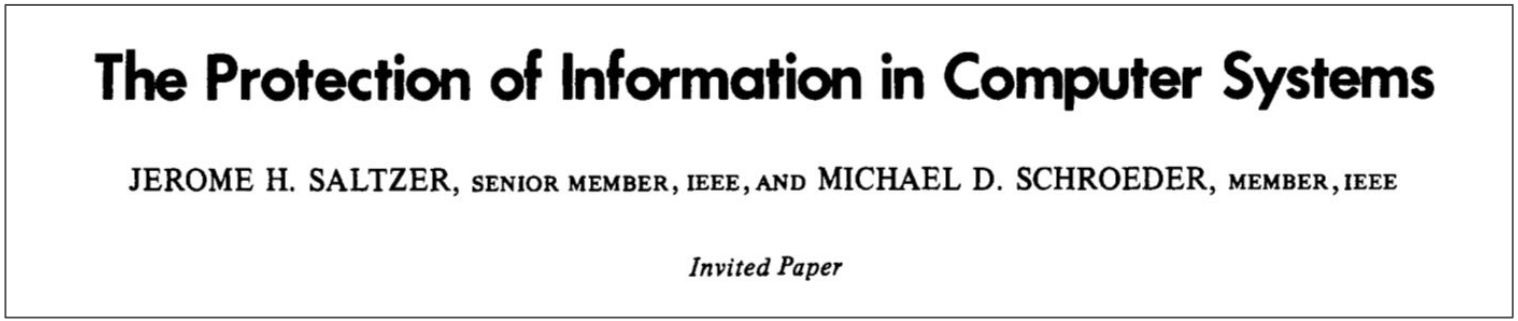
Failsafe Defaults: If the security mechanisms fail, the system should default to a safe mode

Other Key Security Concepts

Defense-in-Depth: Systems should be designed to be secure even if one defensive mechanisms fails

Minimizing the Trusted Computing Base: The part of the system that needs to be trusted in order to mitigate harms should be as small as possible

Failsafe Defaults: If the security mechanisms fail, the system should default to a safe mode



The Protection of Information in Computer Systems

JEROME H. SALTZER, SENIOR MEMBER, IEEE, AND MICHAEL D. SCHROEDER, MEMBER, IEEE

Invited Paper

Proc. IEEE 1975

A Brief History of Computer Security Research through the Dot-Com Years

Examples of Computer Security Research Directions and Impact
and
Considerations for AI Research

A Case Study of Microsoft and Trustworthy Computing
and
Threat Modeling

Microsoft's Trustworthy Computing Announcement

Background: Significant public pressure on Microsoft to increase security

January 15, 2002: Bill Gates (Microsoft) sent his "Trustworthy Computing" memo

- Microsoft was prioritizing its focus on security
- Microsoft would pause Windows development for 1 month
- Microsoft would send 7,000 systems programmers to mandatory, specialized security training
- Microsoft would audit its codebase for security
- Later, Microsoft would do this for other products as well

Estimated costs: "$100 million so far this year" (July 2002), 8,500 engineers with work on hold for 2 months

https://redmondmag.com/articles/2002/01/17/gates-urges-trustworthy-computing-in-memo.aspx
https://www.internetnews.com/it-management/microsoft-spent-100m-on-trustworthy-computing/

Microsoft Trustworthy Computing Announcement

Microsoft's pause of development significantly improved their security

Microsoft's pause led the industry to prioritize and take seriously security

Calls for AI companies to pause is not without precedent

Threat Modeling: The Most Important Security Method

Steve Lipner of Microsoft:

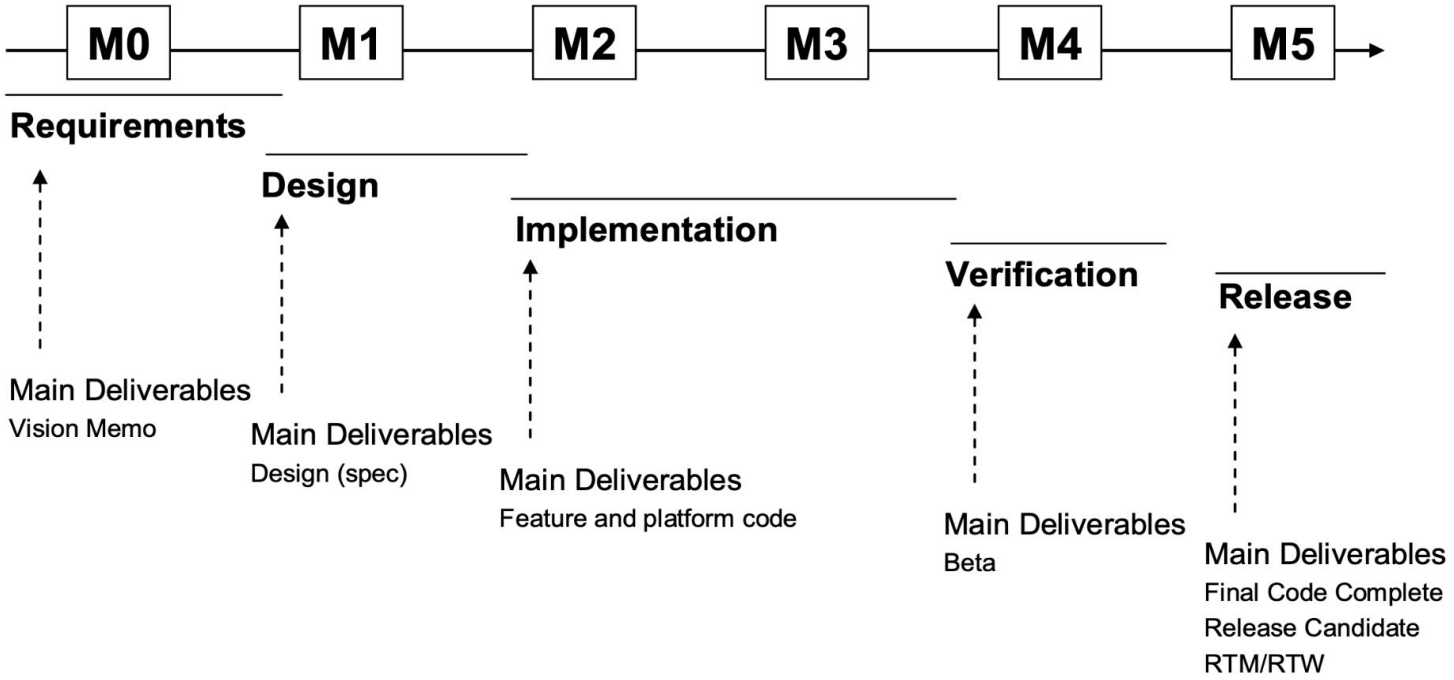
> "The consensus across the SWI (Secure Windows Initiative) team is that **threat modeling is the highest-priority component** of SDL (Security Development Lifecycle)."

(Keynote companion paper, Annual Computer Security Applications Conference 2004)

Adopting threat modeling practices within AI companies – and for AI researchers – could also be the "single most important thing" for AI

https://www.acsac.org/2004/papers/Lipner.pdf

Software Development Lifecycle (Lipner 2004)



https://www.acsac.org/2004/papers/Lipner.pdf

Security Development Lifecycle (Lipner 2004)

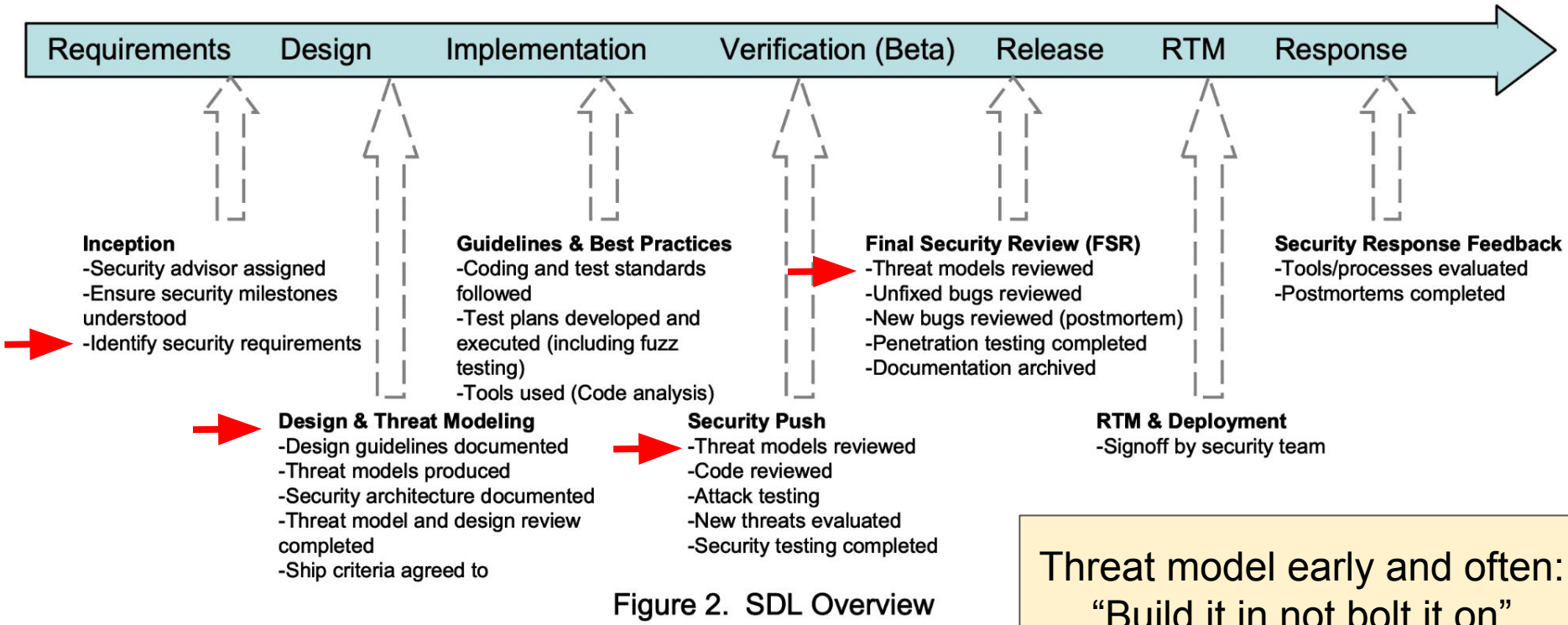


Figure 2. SDL Overview

Threat model early and often:
"Build it in not bolt it on"

https://www.acsac.org/2004/papers/Lipner.pdf

Threat Modeling for AI 101 (Example Method)

1. **Summarize** the **system**
2. **Identify** “all” **stakeholders**
3. **Identify** “all” **assets** for all stakeholders
4. Consider **matrix** of all **stakeholders** x **(stakeholders + assets)**:

   Explore how the stakeholders might **negatively impact** the **other stakeholders’ assets**

	Stakeholder 1, Asset 1	Stakeholder 1, Asset 2	Stakeholder 1, Asset 3	Stakeholder 2, Asset 1	Stakeholder 2, Asset 2
Stakeholder 1					
Stakeholder 2					

Threat Modeling for AI 101 (Example Method)

1. **Summarize** the **system**
2. **Identify** “all” **stakeholders**
3. **Identify** “all” **assets** for all stakeholders
4. Consider **matrix** of all **stakeholders** x **(stakeholders + assets)**:

   Explore how the stakeholders might **negatively impact** the **other stakeholders’ assets**

5. **Prioritize risks**, **develop mitigations**, and **iterate**

Threat Modeling for AI 101 (Example Method)

1. **Summarize** the **system**
2. **Identify** “all” **stakeholders**
3. **Identify** “all” **assets** for all stakeholders
4. Consider **matrix** of all **stakeholders** x **(stakeholders + assets)**:

   Explore how the stakeholders might **negatively impact** the **other stakeholders’ assets**

5. **Prioritize risks**, **develop mitigations**, and **iterate** (possibilities include **redesigning the system** or **not building the system**) (**prevent**, **detect**, **deter**)

Threat Modeling for AI 101 (Example Method)

1. **Summarize** the **system**
2. **Identify** “all” **stakeholders**
3. **Identify** “all” **assets** for all stakeholders
4. Consider **matrix** of all **stakeholders** x **(stakeholders + assets)**:

   Explore how the stakeholders might **negatively impact** the **other stakeholders’ assets**

5. **Prioritize risks**, **develop mitigations**, and **iterate** (possibilities include **redesigning the system** or **not building the system**) (**prevent**, **detect**, **deter**)

AI, Ethics, and Society research helps throughout this process

Threat Modeling for AI 101 (Example Method)

A threat model should be documented and revisited regularly

1. **Summarize** the **system**
2. **Identify** “all” **stakeholders**
3. **Identify** “all” **assets** for all stakeholders
4. Consider **matrix** of all **stakeholders** x **(stakeholders + assets)**:

   Explore how the stakeholders might **negatively impact** the **other stakeholders’ assets**

5. **Prioritize risks**, **develop mitigations**, and **iterate** (possibilities include **redesigning the system** or **not building the system**) (**prevent**, **detect**, **deter**)

AI, Ethics, and Society research helps throughout this process

Thank you!

David Atkinson

Natalie Grace Brigham

Andrea Dean

Rachel Hong

Paul Ohm

Kobbi Nissim

Sejin Paik

Franziska Roesner

Tanina Rostain

Amy Winecoff

Patrick Yurky

Summary

AI, Ethics, and Society is, **today**, similar to where **computer security** was in the **late 1990s and early 2000s**

Computer security, **today**, is **much better** than computer security in the late 1990s and early 2000s

1. There is **hope** for the future of AI, Ethics, and Society
2. AI, Ethics, and Society research may benefit from **considering analogies** with “early” computer security research
3. I encourage consistent **adoption** of **threat modeling** for everyone involved in AI development and analysis (academia, industry, government)